Spyware

A type of malware that secretly watches your activities—like keystrokes, browsing, passwords and sends them to cybercriminals without you knowing.

Shadow AI

When employees use AI tools (ChatGPT, Bard, etc.) without company permission.
Risk: data leakage, no monitoring, no security controls.

DDoS (Distributed Denial of Service)

A cyber attack where thousands of fake requests hit a server at once, making it slow or completely unavailable for real users.
Like a crowd blocking a shop's entrance so customers can't enter.

DPO (Data Protection Officer)

A compliance officer who ensures a company safely handles personal data, prevents data leaks, and follows privacy laws like GDPR or DPDP Act.

Cyber Hygiene

Everyday safety habits to keep systems secure.
Examples:

- Updating software
- Using strong passwords
- Not clicking unknown links
- Backing up data
- Using antivirus

Zero-Day Attack

An attack that targets a brand-new software flaw that even the software company doesn't know about yet.
No patch exists = very dangerous.

Cold Wallet

A crypto wallet stored **offline** (USB device, paper wallet).
Very safe because hackers cannot reach it over the internet.

Hot Wallet

A crypto wallet stored **online** (mobile app, exchange platform).
Easy to use but more vulnerable to hacking.

DMARC / SPF / DKIM

SPF (Sender Policy Framework)
Checks if the email is sent from an approved server for that domain.

DKIM (DomainKeys Identified Mail)
Adds a digital signature to emails so the receiver can verify the email wasn't changed and is truly from the domain.

DMARC (Domain-based Message Authentication, Reporting and Conformance)
A policy that uses SPF and DKIM results to decide whether to **allow, quarantine, or reject** suspicious emails.
Also gives reports about email spoofing attempts.

DDoS Negating Servers (Example)

If a bank website normally handles 20,000 users/day, but hackers send 2 million fake users, the server crashes.
Result: Website down, transactions fail, customers locked out.

DSPM (Data Security Posture Management)

A security tool that finds where sensitive data is stored across cloud services, checks who can access it, and alerts on risks like public exposure or misconfigurations.

SOC (Security Operations Center)

A team/department that monitors an organization's systems 24×7 to detect attacks, investigate alerts, and respond to threats in real time.

SOAR (Security Orchestration, Automation & Response)

A system that helps the SOC by:

- Automating repetitive tasks
- Integrating security tools
- Running playbooks for faster incident response
  Reduces human workload and speeds up handling attacks.

ISO 27001 (Information Security Management System)

Issued by (India):

- BSI India
- TÜV SÜD India
- SGS India
- DNV India
- IRCLASS

Industry Mandatory?
Not mandatory, but widely required in:

ISO 27701 (Privacy Information Management)

Issued by: Same bodies that issue ISO 27001.

Mandatory? No.
Industry: Any company handling personal data.
Regulators: Supports GDPR, DPDP Act (India).

ISO 22301 (Business Continuity Management)

Issued by: BSI, TÜV, SGS, DNV, etc.
Mandatory? No.
Industry:

- Banks
- Government
- Critical infrastructure
  Regulator: Helps meet RBI business continuity requirements.

SOC 2 Type I & Type II

Issued by (Worldwide):
Certified Public Accountants (CPAs) / AICPA-authorized auditors.

Issued by (India):
Big 4 audit firms:

- Deloitte
- EY
- KPMG
- PwC
  and AICPA-licensed firms.

Mandatory? No.
Industry:

- SaaS
- Cloud
- BPO
- IT Services

Regulator Requirement?
Not mandatory but essential for US clients + cloud companies.

PCI-DSS (Payment Card Industry Data Security Standard)

Issued by:
PCI Security Standards Council + Qualified Security Assessors (QSAs).

Issued in India by:

- SISA
- Panacea Infosec

- ControlCase
- VISTA InfoSec

Mandatory?
YES — mandatory for anyone handling card data (Visa, Mastercard, RuPay).

Industry:

- Banks
- Payment gateways
- Wallets
- E-commerce
- POS vendors

Regulator:
Required by **RBI** for card data security.

HIPAA (Healthcare Data – USA)

Issued by:
No central certificate.
Compliance validated by:

- HHS (US regulator)
- Third-party HIPAA auditors

Mandatory?
YES for healthcare organizations handling patient data.

Industry:
Hospitals, insurance, health tech.

NIST CSF (Cybersecurity Framework – USA)

Issued by:
Not a certification.
Framework created by **NIST (National Institute of Standards and Technology)**.

Mandatory?
No (except for some US federal contractors).

Industry:
Any — used globally.

CMMC (US Department of Defense)

Issued by:
CMMC Accreditation Body (CMMC-AB).

Mandatory?
YES for companies working with the US DoD.

Industry:
Defense contractors, aerospace suppliers.

CSA STAR (Cloud Security Alliance)

Issued by:
Cloud Security Alliance.

Mandatory?
No.
Industry: Cloud service providers (SaaS, PaaS, IaaS).

FedRAMP (US Federal Government)

Issued by:
FedRAMP PMO + 3PAO (Third Party Assessment Organizations).

Mandatory?
YES for any cloud service provider serving US federal agencies.

SWIFT CSP (Banks Using SWIFT)

Issued by:
SWIFT organization (Belgium).

Mandatory?
YES for banks and financial institutions using SWIFT for international payments.

Industry:
Banking & finance.

Regulator (India):
RBI indirectly expects compliance.

RBI Cybersecurity Framework (India – Banks/NBFCs)

Issued by:
Reserve Bank of India.

Mandatory?
YES for:

- Banks
- NBFCs
- Payment system providers
- Wallet operators

Requires:

- Cybersecurity Policy
- Incident reporting
- SOC
- VAPT
- Data protection

CERT-In Compliance (India)

Issued by:
CERT-In (Indian Computer Emergency Response Team).

Mandatory?
YES for:

- Service providers
- Intermediaries
- Data centers
- VPN providers
- Cloud providers
- Crypto exchanges

Requires:

- 6-hour incident reporting
- Log retention (180 days)
- Security baseline practices